CSTE 4103 Questions Solve:

1. a)

A secure communication system is being developed for a small financial company. During a technical meeting, the system's security analyst explains that several parts of the system—such as key generation, digital signatures, hashing, and encryption—will rely on modular arithmetic. To illustrate this, the analyst presents a simple example in which each bit of a message is combined with a key bit using modulo-2 addition (XOR) to provide basic encryption.

(2+2 = 4)

i. Why is modular arithmetic essential in cryptography, especially in designing the company's secure communication system?

(2 marks)

Answer:

Modular arithmetic allows cryptographic operations to work within a finite range, making encryption, decryption, and key generation efficient and secure. It also provides mathematical hardness that protects cryptographic systems from attacks.

---

ii. Why is modulo-2 addition (XOR) considered as an effective encryption operation in cryptographic algorithms? Explain using properties that are relevant to the system.

(2 marks)

Answer:

XOR is effective because it is fast, simple, and reversible, allowing easy encryption and decryption using the same key. A change in either the message or key changes the output, providing confusion.

---

1. b)

A network administrator notices that two internal employees are exchanging encrypted messages repeatedly. The encryption algorithm uses a fixed key and appears to be a simple substitution cipher. The security team suspects data leakage. Now answer the following questions on the above scenario:

(3 × 1 = 3)

i. As a cryptanalyst, which cryptanalysis technique would you apply first to break this cipher? Explain why.

(1 mark)

Answer:

Frequency analysis, because a simple substitution cipher preserves letter frequency patterns.

---

ii. If you successfully recover part of the plaintext, how can you use that information to recover the key?

(1 mark)

Answer:

Recovered plaintext reveals plaintext–ciphertext mappings, which directly expose parts of the substitution key.

Alternative Answer:

By XORing the recovered plaintext with the corresponding ciphertext, the key (or key stream) bits can be directly obtained, since

Key=Plaintext ⊕ Ciphertext

---

iii. What weaknesses in a simple substitution cipher make it vulnerable to cryptanalysis?

(1 mark)

Answer:

It uses a fixed key and preserves statistical patterns, making frequency-based attacks effective.

---

1. c)

A software company has designed a new lightweight block cipher for IoT devices. Before deployment, the security team conducts a cryptanalysis review. During testing, analysts observe two possible attack paths:

- **One attack studies how differences in plaintext affect differences in ciphertext.**
- **Another attack tries to find linear equations that approximate the cipher's internal operations.**

  (2 × 1.5 = 3)

i. Identify which attack corresponds to differential cryptanalysis and which corresponds to linear cryptanalysis.

(1.5 marks)

Answer:

Differential cryptanalysis is a **chosen-plaintext attack**, where the attacker selects plaintexts and studies the resulting ciphertext differences.

Linear cryptanalysis is a **known-plaintext attack**, where the attacker uses known plaintext–ciphertext pairs to find linear relations involving key bits.

---

ii. Explain, based on this scenario, the fundamental difference between the two analyses.

(1.5 marks)

Answer:

Differential cryptanalysis is a *chosen-plaintext attack* that analyzes how plaintext differences lead to ciphertext differences.

Linear cryptanalysis is a *known-plaintext attack* that exploits linear approximations between plaintext, ciphertext, and key bits.

2. a)

A financial technology company launches an online payment platform where every transaction requires a unique cryptographic nonce and a temporary session key. These values are generated using a fast software PRNG to reduce computation time. After a security breach, investigators discover the following issues:

- **The PRNG occasionally repeats values when the server experiences high load.**
- **The attacker was able to replay previous encrypted transactions because some nonces were reused.**
- **The randomness tests show a low level of entropy in the generated keys.**

The company now wants to redesign the system using either a cryptographically secure PRNG (CSPRNG) or a hardware-based TRNG. Based on this scenario, answer the following:

(3 × 1 = 3)

---

i. Why did the reuse of PRNG-generated nonces lead to successful replay attacks?

(1 mark)

Answer: Reusing PRNG-generated nonces with the same seed produces identical nonce values, causing repeated encryption patterns that attackers can capture and replay to be accepted as valid messages.

Alternative Answer:
Reused nonces make encrypted transactions identical or predictable, allowing attackers to replay old messages and have them accepted as valid.

---

ii. What characteristics of a CSPRNG would have prevented the attacker from predicting or reusing session keys?

(1 mark)

Answer:

A CSPRNG provides high entropy, unpredictability, and resistance to state compromise, preventing nonce repetition and key prediction.

---

iii. In what situations would a TRNG (True RNG) be preferable over a CSPRNG for this payment system?

(1 mark)

Answer:

A TRNG is preferable for generating long-term master keys or high-security nonces where maximum unpredictability is required.

---

2. b)

A client connects to a server but receives the error: “Certificate not trusted”. List possible reasons and how you would diagnose them.

(4 marks)

Answer:

The error may occur due to an expired certificate, an untrusted certificate authority, a domain name mismatch, missing intermediate certificates, or an incorrect system clock.

Diagnosis involves checking the certificate chain, verifying expiry dates, confirming the domain name, and inspecting the trust store using browser tools or OpenSSL.

---

2. c)

A museum finds old military messages encrypted using different substitution techniques. Experts determine:

- **Message A was encrypted using a Caesar shift.**
- **Message B was encrypted using a general monoalphabetic cipher.**
- **Message C was encrypted using a repeated-key polyalphabetic cipher.**

Questions:

(3 × 1 = 3)

---

i. Which message can be broken the fastest? Explain why.

(1 mark)

Answer:

Message A, because the Caesar cipher has only 26 possible keys and can be brute-forced easily.

---

ii. Which message requires frequency analysis of grouped letters instead of individual letters?

(1 mark)

Answer:

Message C, because repeated-key polyalphabetic ciphers require analysis of grouped letters to detect periodic patterns.

---

iii. Which message's security depends strongly on the secrecy and length of the key?

(1 mark)

Answer:

Message C, since a longer and secret key reduces repetition and increases resistance to cryptanalysis.

3. a)

A mobile banking application uses a modern block cipher to secure all user transactions. During a security review, the cryptography engineer notices the following:

- **When a single bit of the plaintext changes, half of the ciphertext bits change in a seemingly random pattern.**
- **When the secret key is slightly modified, the resulting ciphertext becomes completely unpredictable, even for the same plaintext.**
- **The engineer explains that these two behaviors demonstrate the cipher's "diffusion" and "confusion" properties.**

Based on the scenario, identify which observed behaviour represents diffusion and which represents confusion. Explain your reasoning clearly.

(3 marks)

Answer:

The first behaviour represents **diffusion**, because a small change in plaintext affects many bits of the ciphertext, spreading the influence of each input bit.

The second behaviour represents **confusion**, because a small change in the key causes unpredictable changes in ciphertext, hiding the relationship between the key and ciphertext.

Both properties together strengthen resistance against cryptanalysis.

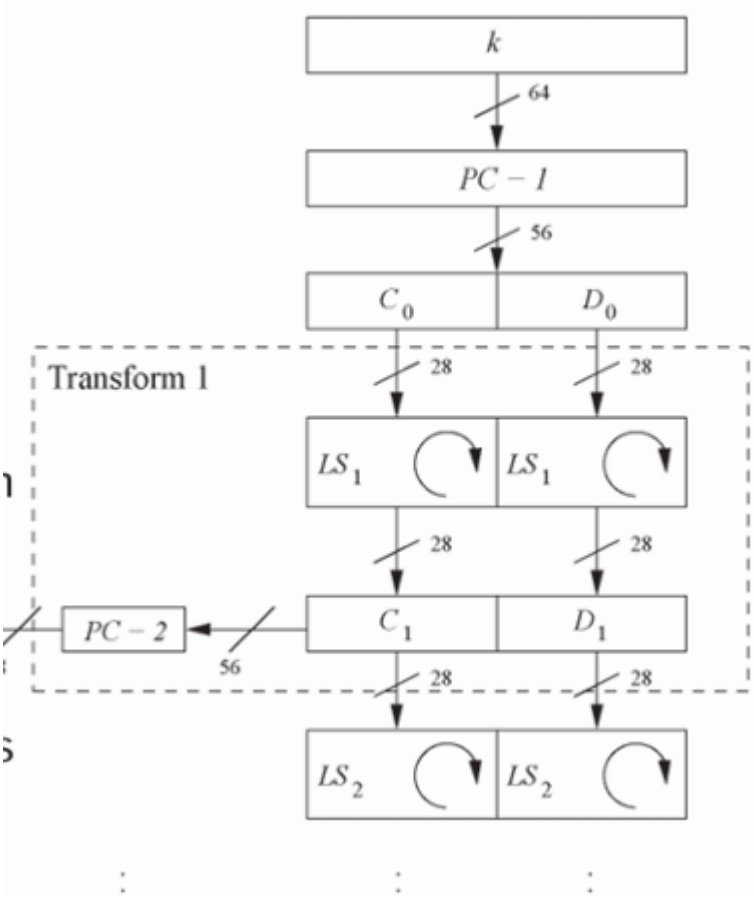
---

3. b)

Show that in DES the first 24 bits of each subkey come from the same subset of 28 bits of the initial key and that the second 24 bits of each subkey come from a disjoint subset of 28 bits of the initial key.

(3 marks)

Answer:



In DES, the 56-bit key is divided into two 28-bit halves, C and D.

During key scheduling, each round subkey (48 bits) is formed by selecting **24 bits from C** and **24 bits from D** using fixed permutation tables.

Since C and D are disjoint subsets of the original key, the two 24-bit portions of every subkey also come from disjoint 28-bit subsets.

3. c)

Compute the differential distribution table (DDT) of the following 3-bit S-box:

S={6,5,0,7,3,2,4,1} **and determine whether it is a "good" S-box.**

(4 marks)

Differential Distribution Table (DDT

ΔX \ ΔY	0	1	2	3	4	5	6	7
0	8	0	0	0	0	0	0	0
1	0	2	2	0	0	2	2	0
2	0	0	0	2	2	0	0	4
3	0	2	2	0	0	2	2	0
4	0	0	0	2	2	0	0	4
5	0	2	2	0	0	2	2	0
6	0	0	0	2	2	0	0	4
7	0	2	2	0	0	2	2	0

The maximum non-zero entry in the DDT is **4**, which is acceptable for a 3-bit S-box.

Since no input difference leads to a highly biased output difference, the given S-box can be considered a **good S-box** against differential cryptanalysis.

4. a)

Illustrate the overall structure of the AES encryption algorithm and explain its main stages.

(5 marks)

Answer:

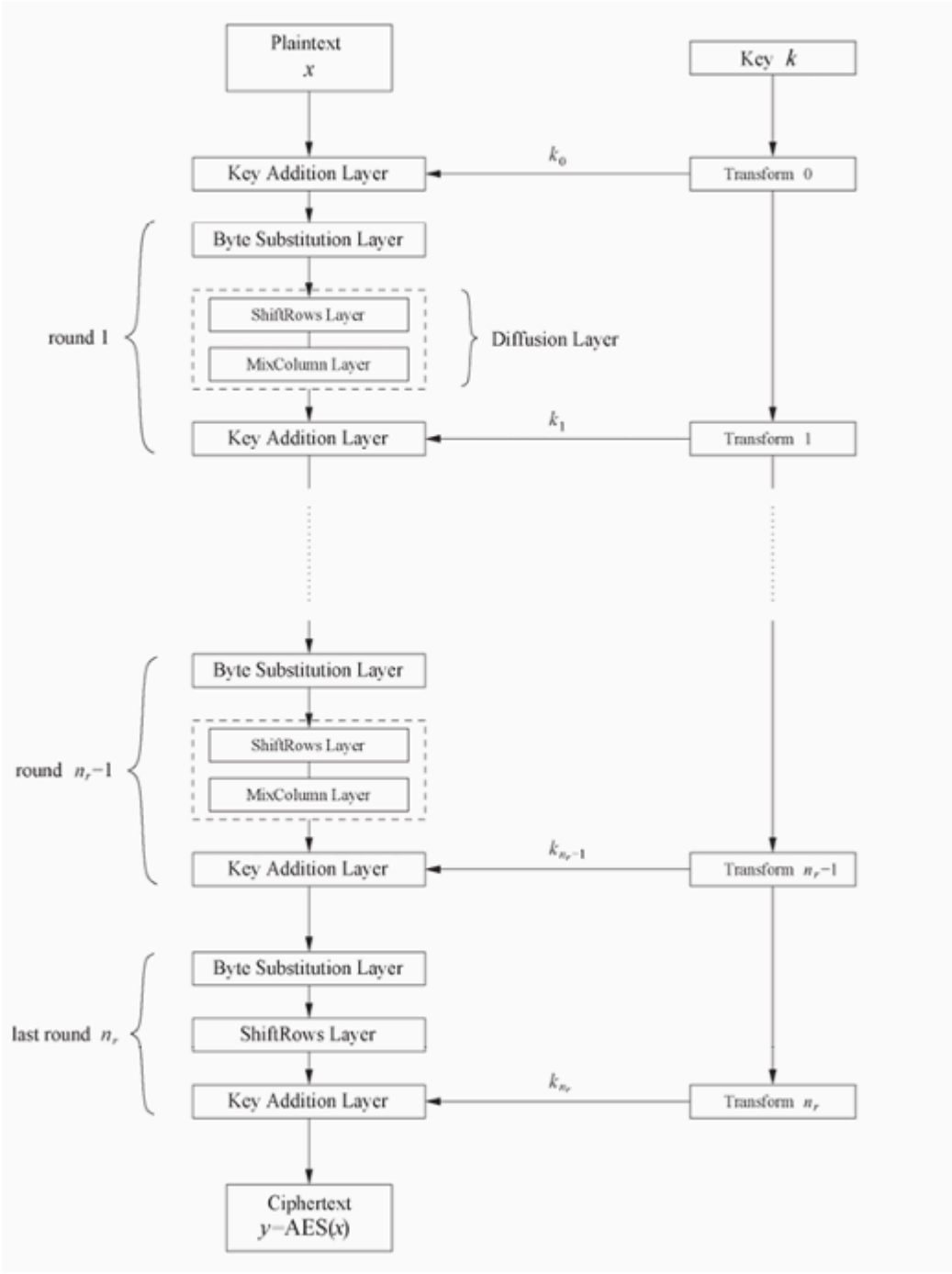
AES (Advanced Encryption Standard) is a symmetric block cipher that operates on **128-bit plaintext blocks** and supports key sizes of **128, 192, and 256 bits**. The plaintext is arranged into a **4 × 4 byte state matrix**.

Encryption starts with an **initial AddRoundKey** operation, followed by a number of rounds (10 for AES-128, 12 for AES-192, and 14 for AES-256). Each round consists of four main stages:

- **SubBytes:** Each byte is substituted using a non-linear S-box to provide confusion.

- **ShiftRows:** Rows of the state matrix are cyclically shifted to increase diffusion.
- **MixColumns:** Each column is mixed using Galois field arithmetic to further spread plaintext influence.
- **AddRoundKey:** The round key is XORed with the state.

The **final round omits the MixColumns step**, producing the ciphertext.



[Diagram: Overall structure of AES encryption]

---

4. b)

A company wants to upgrade from AES-128 to AES-256 for higher security. Analyze whether the performance loss is justified for typical applications.

(3 marks)

Answer:

AES is a block cipher with a fixed 128-bit block size, and AES-128 already provides a very high level of security for typical applications. Upgrading to AES-256 increases computational overhead due to more rounds, making it more time- and resource-consuming. Therefore, the performance loss is generally not justified unless protecting extremely sensitive or long-term data.

---

4. c)

Explain why AES is considered efficient for both software and hardware implementations.

(2 marks)

Answer:

AES is efficient in software because it uses precomputed lookup tables (such as S-box tables), enabling fast execution on general-purpose processors. In hardware, AES relies on simple byte-oriented operations like XOR, substitution, and shifting, which makes it easy to implement with low complexity and well-suited for embedded systems.

5. a)

Define a Galois field. Explain Galois Counter Mode.

(1 + 2 = 3)

Answer:

Galois Field:
A Galois field is a finite field in which arithmetic operations (addition and multiplication) are performed modulo a prime number or an irreducible polynomial, such as $\mathrm{GF}(2^{128})$ used in AES-GCM.

Galois Counter Mode (GCM):
GCM is a block cipher mode that combines **counter-mode encryption** with **Galois field–based authentication** to provide confidentiality and integrity.

For encryption, an initial counter CTR_0 is derived from the IV, and subsequent counters are incremented:

$$y_i = E_k(\mathrm{CTR}_i) \oplus x_i, \quad \mathrm{CTR}_i = \mathrm{CTR}_0 + i$$

For authentication, a hash subkey $H = E_k(0)$ is generated and chained Galois field multiplications in $\mathrm{GF}(2^{128})$ are used to compute the authentication tag, ensuring message integrity and authenticity.

---

5. b)

Explain the core security services.

(3 marks)

Answer:

The core security services are:

1. **Confidentiality** – Ensures that information is kept secret and only accessible to authorized users.
2. **Integrity** – Guarantees that data is not altered or modified during storage or transmission.
3. **Authentication (Message Authentication)** – Verifies that the message is sent by the legitimate sender.
4. **Non-repudiation** – Prevents the sender from denying having sent a message at a later time.

---

5. c)

Describe how birthday paradox leads to a birthday attack on hash functions. Apply this concept to explain why hash functions with 64-bit output are considered insecure.

(4 marks)

Answer:

The birthday paradox shows that collisions occur with surprisingly high probability when many random values are generated. In cryptography, this leads to **birthday attacks**, where attackers find two different inputs producing the same hash value faster than expected.

For an n-bit hash function, a collision can be found in about $2^{n/2}$ attempts. Therefore, for a **64-bit hash**, collisions can be found in approximately 2^{32} operations, which is computationally feasible. Hence, hash functions with 64-bit output are considered insecure.

6. a)

Perform encryption and decryption using the RSA algorithm for p = 3, q = 11, e = 7 and the plaintext input, M = 5.

(4 marks)

Answer:

Step 1: Key generation

$$n = p \times q = 3 \times 11 = 33$$

$$\phi(n) = (3-1)(11-1) = 2 \times 10 = 20$$

Given $e = 7$.

Find d such that:

$$7d \equiv 1 \pmod{20}$$

$$d = 3$$

Step 2: Encryption

$$C = M^e \bmod n = 5^7 \bmod 33 = 14$$

Step 3: Decryption

$$M = C^d \bmod n = 14^3 \bmod 33 = 5$$

Thus, encryption and decryption are verified successfully.

6. b)

Why are parameters significantly smaller for elliptic curves (160–256 bit) than for RSA (1024–3076 bit)?

(2 marks)

Answer:

Elliptic Curve Cryptography is based on the Elliptic Curve Discrete Logarithm Problem, which is much harder to solve than integer factorization used in RSA. Hence, ECC achieves the same security level with much smaller key sizes.

---

6. c)

Ali has public key (5, 91) and private key (29, 91). He wants to sign the document m = 7 and send it to Bred.

(4 marks)

i) What is the signed document?

Answer:

The signature is computed using the private key:

$$S = m^d \bmod n = 7^{29} \bmod 91 = 63$$

---

ii) Show Bred's calculations that verify the document is valid.

Answer:

Bred verifies the signature using Ali's public key:

$$m = S^e \bmod n = 63^5 \bmod 91 = 7$$

Since the recovered message equals the original message, the signature is valid.

7. a)

What is the discrete logarithm problem of Diffie-Hellman key exchange?

(3 marks)

Answer:

In the Diffie–Hellman key exchange, the **discrete logarithm problem (DLP)** is defined in the multiplicative group $\mathbb{Z}_p^*$, where p is a large prime and α is a **primitive element (generator)** of the group.

Given public values p, α, and $\beta = \alpha^x \bmod p$, the discrete logarithm problem is to find the secret exponent x such that:

$$\alpha^x \equiv \beta \pmod{p}$$

In Diffie–Hellman, Alice and Bob compute their public values using the primitive element α as $A = \alpha^a \bmod p$ and $B = \alpha^b \bmod p$. While exponentiation modulo p is easy, computing the private keys a or b from A or B is computationally infeasible for large p. The security of Diffie–Hellman relies on the hardness of this discrete logarithm problem.

---

7. b)

"Key whitening enlarges the DES key length without much computational overhead" – Explain.

(2 marks)

Answer:

Key whitening increases DES security by XORing extra key bits with the plaintext and ciphertext before and after encryption. This effectively increases the key length with minimal computational cost since XOR operations are very fast.

---

7. c)

What is Digital Signature Algorithm (DSA)? Explain DSA.

(5 marks)

Answer:

Digital Signature Algorithm (DSA) is a **public-key cryptographic algorithm** used for generating and verifying **digital signatures**. It provides **authentication, integrity, and non-repudiation** and is based on the **Discrete Logarithm Problem**. DSA is used only for signing and verification, not for encryption.

Working of DSA

1. Key Generation

1. Choose a large prime number p.
2. Choose a prime q such that $q \mid (p-1)$.
3. Choose a generator g.
4. Choose a private key d, where $0 < d < q$.
5. Compute the public key:

$$\beta = g^d \bmod p$$

- Public key: (p, q, g, β)
- Private key: d

2. Signature Generation

1. Compute the hash of the message $H(m)$.
2. Choose a random number k, where $0 < k < q$.
3. Compute:

$$r = (g^k \bmod p) \bmod q$$

4. Compute:

$$s = k^{-1}(H(m) + d \cdot r) \bmod q$$

The signature is the pair (r, s).

3. Signature Verification

1. Compute $w = s^{-1} \bmod q$.
2. Compute $u_1 = w \cdot H(m) \bmod q$.
3. Compute $u_2 = w \cdot r \bmod q$.
4. Compute:

$$v = (g^{u_1} \cdot \beta^{u_2} \bmod p) \bmod q$$

If $v = r$, the signature is valid.

8. a)

Explain the Elliptic Curve Digital Signature Algorithm

(4 marks)

Answer:

Elliptic Curve Digital Signature Algorithm (ECDSA) is a **public-key digital signature scheme** based on **Elliptic Curve Cryptography (ECC)**.

It is used to provide **authentication, data integrity, and non-repudiation**.

ECDSA is based on the hardness of the **Elliptic Curve Discrete Logarithm Problem (ECDLP)** and achieves strong security with smaller key sizes.

Working of ECDSA

---

1. Key Generation

- Choose an elliptic curve and a base point G of order n.
- Select a private key d, where $1 \leq d \leq n - 1$.
- Compute the public key:

$$Q = dG$$

- **Public key:** (Q, G, n)
- **Private key:** d

- **Public key:** (Q, G, n)
- **Private key:** d

---

2. Signature Generation

To sign a message m:

1. Compute the hash of the message:

$$e = Hash(m)$$

2. Choose a random number k, where $1 \leq k \leq n - 1$.
3. Compute:

$$r = (kG)_x \bmod n$$

---

4. Compute:

$$s = k^{-1}(e + dr) \bmod n$$

- The digital signature is the pair:

$$(r, s)$$

---

3. Signature Verification

To verify the signature (r, s):

1. Compute:

$$e = Hash(m)$$

2. Compute:

$$w = s^{-1} \bmod n$$

3. Compute:

$$u_1 = ew \bmod n, \quad u_2 = rw \bmod n$$

4. Compute:

$$X = u_1 G + u_2 Q$$

- The signature is **valid if**:

$$X_x \bmod n = r$$

ECDSA provides secure digital signatures using elliptic curves and offers high security with smaller key sizes compared to RSA.

8. b)

Answer the following questions on RSA Attacks:

(3 × 2 = 6)

(i) How can weaknesses in the RSA parameter selection (such as small public exponents or poorly chosen primes) lead to analytical attacks? Explain with an example.

(2 marks)

Answer:

Weak RSA parameters, such as a very small public exponent or poorly chosen primes, can make RSA vulnerable to analytical attacks.

For example, using a small public exponent e=3without proper padding can allow **Håstad's broadcast attack**, enabling attackers to recover the plaintext without the private key.

(ii) What mathematical properties of RSA can attackers exploit to break the system, and why does the difficulty of factoring large integers protect RSA against such attacks?

(2 marks)

Answer:

Attackers can exploit the fact that knowing the factors of n=pq allows computation of the private key.

RSA remains secure because factoring large integers is computationally infeasible, making it impractical to derive the private key from the public key.

(iii) RSA is mathematically secure, yet real-world systems using RSA can be compromised. What implementation mistakes can lead to RSA being broken, even if the underlying mathematics is sound? Give two examples.

(2 marks)

Answer:

RSA can be broken due to implementation errors such as **using RSA without proper padding** and **leakage through side-channel attacks** (timing or power analysis).

These mistakes expose information about the private key even though the RSA algorithm itself is secure.

9. a)

A company's network receives thousands of incoming and outgoing packets every minute. One afternoon, it was discovered that packets were originating from an unknown IP address attempting to access the company's internal database server. Based on this scenario, explain how the firewall decides which traffic to allow or block, and why this decision-making process is crucial for protecting the company's network.

(2 marks)

Answer:

A firewall examines packet attributes such as source IP address, destination IP, port number, and protocol, and compares them with predefined security rules to allow or block traffic. This decision-making process is crucial because it prevents unauthorized access and protects internal resources from external attacks.

---

9. b)

A company is upgrading its e-commerce website to improve security. During the audit, the security team discovers that the website is still using SSL 3.0 for secure communication. The auditor notes that:

- **Some browsers are rejecting the connection due to outdated security protocols.**
- **Attackers recently attempted a downgrade attack to force weaker encryption.**
- **The company plans to switch to TLS 1.3 to strengthen encryption and improve performance.**

Based on this scenario, explain the difference between SSL and TLS. In your answer, discuss why modern systems prefer TLS over SSL, how TLS provides stronger protection against attacks.

(2 + 2 + 1 = 5)

Answer:

Difference between SSL and TLS

SSL	TLS
Older security protocol	Newer and improved version
Uses weaker cryptographic algorithms	Uses stronger and modern algorithms
Vulnerable to downgrade and known attacks	Resistant to known and downgrade attacks
Slower handshake process	Faster and more secure handshake

Why modern systems prefer TLS:
Modern systems prefer TLS because it provides **stronger security** through improved encryption algorithms and safer key-exchange mechanisms. TLS also

offers **better performance** with a faster and more efficient handshake process and protects against **known vulnerabilities and downgrade attacks** present in SSL, making SSL obsolete for secure communication.

How TLS provides stronger protection:

TLS uses stronger encryption algorithms, improved key exchange mechanisms, and secure handshake processes to prevent modern attacks.

---

9. c)

A company's firewall is experiencing performance issues. Describe possible causes and propose three optimization solutions.

(3 marks)

Answer:

Firewall performance issues can occur due to **high traffic volume**, **large and complex rule sets**, or **limited processing power and memory** of the firewall device. Deep packet inspection and logging of all packets can also slow down performance.

To optimize firewall performance:

1. **Simplify and reorder firewall rules** so that frequently matched rules are processed first.
2. **Upgrade firewall hardware or enable load balancing** to handle high traffic efficiently.
3. **Disable unnecessary inspections and logging** and allow trusted traffic through faster paths.